המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 02/11/2025 שעת הבחינה: 15:00
שנה"ל: תשפ"ה סמסטר: קיץ מועד: ב'
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:20 שעות

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- בכל שאלה יש לסמן את התשובה הנכונה ביותר בדף הקידוד. **רק דף הקידוד ייבדק!**
- את התשובות יש לסמן **בעט שחור או כחול כהה בלבד, באופן ברור ומודגש. יש להקפיד על כתב יד קריא וברור**
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֵר) זוהר
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 15:20, 15:50. לזכאי תוספת זמן גם בשעה 16:20

נא **לא לשאול** את השאלות הבאות בעזרת פתקים, כי לא יינתן עליהם מענה:
- יש טעות בבחינה/בשאלה/בסעיף...
- יש יותר מתשובה אחת נכונה או אף אחת מהתשובות לא נכונה.
- לא למדנו על...
- מה התרגום של [משהו] בעברית/באנגלית...
- מה המשמעות של ראשי התיבות...
- כל שאלה שעיקרה לגרום לגילוי התשובה

חשוב מאוד:
- בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)

- יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

בכל השאלות הבאות, התשובה הנכונה היא סעיף א.

<u>שאלה מספר 1:</u>

להלן פסאודו-קוד המציג פונק׳ המטפלת בצורה קריפטוגרפית במידע:

```
function foo(key_encryption, key_mac, ciphertext, tag):
    if VerifyMAC(key_mac, ciphertext) != tag:
        return "Invalid"!
    else:
        return Decrypt(key_encryption, ciphertext)
```

מהי השיטה בשימוש על פי פסאדו-קוד זה?

א. Encrypt then MAC

ב. MAC then Encrypt

ג. Encrypt and MAC

ד. Salt and Pepper

<u>שאלה מספר 2:</u>

ב TLS, נתון כי תוקף Man in the middle החליף תו בהודעת ה ClientHello שהלקוח שלח לשרת. מה השלב המוקדם ביותר שזה יתגלה?

א. מיד לאחר שה ClientFinish הגיע לשרת

ב. מיד לאחר שה ClientHello הגיע לשרת

ג. מיד לאחר שה ServerHello הגיע ללקוח

ד. מיד לאחר שה ClientKeyExchange הגיע לשרת

<u>שאלה מספר 3:</u>

מהי הטענה הנכונה?

א. ב Dom based XSS הקוד הפגיע (הקוד עם החולשה) מורץ בדפדפן

ב. מנגנון ה Same Origin Policy מונע Dom based XSS אך לא מונע Reflected XSS

ג. ב Dom based XSS הקוד הפגיע (הקוד עם החולשה) מורץ בשרת

ד. מנגנון ה Same Origin Policy מונע Reflected XSS אך לא מונע Dom based XSS

<u>שאלה מספר 4:</u>

כאשר אליס נרשמת לאתר אינטרנט מסוים, נתון שהאתר לא שומר את הסיסמא עצמה של אליס, אלא מייצר salt ארוך ואקראי, ושומר עבור אליס את ה salt ואת תוצאת ביצוע hash על שרשור של ה salt עם הסיסמא של אליס, כלומר התוצאה של:

hash(salt || password)

עם זאת, במקרה נדיר, יכול להיות שמשתמש שאינו אליס, יוכל להתחבר בהצלחה ליוזר של אליס באתר זה, וזאת למרות שהוא אינו יודע את הסיסמא של אליס, ויתרה מכך, הוא מתחבר עם סיסמא שהיא שונה מהסיסמא שאליס נרשמה איתה לאתר. מהי התופעה שתגרום לכך?

א. Hash collision

ב. Pepper

ג. Certificate Transparency

ד. HSTS

<u>שאלה מספר 5:</u>

מה בביטקוין מונע Double spending?

א. לתוקף אין מספיק משאבים חישוביים כי בביטקוין יש קונצנזוס סביב הבלוקצ׳יין בו מאמצים תמיד את השרשרת הארוכה ביותר, ולכן המתנה של מספיק בלוקים תפתור forkים שיכלו לשמש ל double spending.

ב. הביטקוין צמוד למשאב יציב (ספציפית, לערכו של הזהב), ולכן לתוקף אין מספיק זהב כדי לגרום שיתבצע double spending גם בביטקוין וגם בזהב.

ג. מנגנון ה escrow transactions בו כל משתמש ביטקוין חייב ״לנעול״ בערבון מספיק ביטקוין מראש כך שאם ייתפס ינקו את הקנס מהערבון.

ד. מנגנון ה escrow transactions בו כל miner חייב ״לנעול״ בערבון מספיק ביטקוין מראש כך שאם ייתפס שהminer אפשר לתוקף לבצע double spending ינקו את הקנס מהערבון של ה miner.

<u>שאלה מספר 6:</u>

בהקשר של textbook RSA (כלומר ללא hash), בחרו את שני המספרים הראשוניים הבאים:

p = 5

q = 7

מהערכים הללו, יצרו את המפתח הפומבי הבא:

n = 35

e = 11

מה מבין הבאים הינו מפתח פרטי מתאים?

א. n = 35, d = 11

ב. n = 35, d = 12

ג. n = 35, d = 13

ד. n = 5, d = 12

<u>שאלה מספר 7:</u>

כיצד דפדפנים אוכפים את השימוש ב Certificate Transparency (CT)?

א. הדפדפן דורש שלתעודה תקינה יהיה מספר SCTs שנחתמו על ידי לוגרים שהדפדפן סומך עליהם.

ב. הדפדפן בודק את התעודה מול הCRL של הCA שהנפיק את התעודה.

ג. הדפדפן דורש שהתעודה תוצפן בעזרת המפתח הסימטרי של הלוגרים.

ד. הדפדפן בודק האם המוניטורים הצפינו את התעודה ואחסנו את תוצאת ההצפנה אצל הלוגרים.

<u>שאלה מספר 8:</u>

מה מבין הבאים היא ההגדרה של תכונת ה second pre image resistance?

א.

Given a random message m_0, it is hard to find a message m_1 that is not equal to m_0 such that $h(m_0) = h(m_1)$

ב.

Given a digest d of a random message, it is hard to find a message m such that d = h(m)

ג.

It is hard to find messages $m_0 \neq m_1$ such that $h(m_0) = h(m_1)$

ד.

It is hard to find messages $m_0 \neq m_1$ such that $h(m_0) \neq h(m_1)$

<u>שאלה מספר 9:</u>

אם אתר אינטרנט רוצה שדפדפנים יפנו אליו תמיד ב HTTPS ולא ב HTTP שאינו על גבי TLS, כולל דפדפנים שמעולם לא גלשו אליו, עליו להשתמש ב:

א. HSTS preload

ב. Same Origin Policy

ג. OCSP

ד. OCSP stapling

<u>שאלה מספר 10:</u>

בצופן החלפה מונואלפבתי של השפה האנגלית (בה יש 26 אותיות), תוקף יודע שבciphertext מסויים האות X בciphertext מחליפה את האות Y בplaintext. כמה מפתחות ישנם שיכולים להתאים (מתוך מרחב המפתחות שהיה אם התוקף לא היה יודע את המידע הזה)?

א. 25!

ב. 26!

ג. 26

ד. 26!-2

--- סוף המבחן ---